Федеральное государственное бюджетное образовательное
учреждение высшего образования
«РОССИЙСКАЯ АКАДЕМИЯ НАРОДНОГО
ХОЗЯЙСТВА И ГОСУДАРСТВЕННОЙ СЛУЖБЫ
при ПРЕЗИДЕНТЕ РОССИЙСКОЙ ФЕДЕРАЦИИ»

СИБИРСКИЙ ИНСТИТУТ УПРАВЛЕНИЯ-филиал РАНХиГС

Направление подготовки: «Информационные системы и программирование» Образовательная программа: 09.02.07

Лабораторная №1

по дисциплине: Обеспечение качества функционирования компьютерных систем

на тему:
«Поиск уязвимостей веб-приложения OWASP Juice Shop»

Автор работы:
Студент 4 курса группы К-ИСП-2302
Очной формы обучения
Васильев Константин Сергеевич

Новосибирск, 2026 г.

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3
1. Найти «Табло» (Score Board) 4
2. Прочитать политику конфиденциальности (Privacy Policy) 5
3. Вход в учётную запись администратора через SQL-инъекцию (Login Admin) 6
4. Доступ к разделу администратора (Admin Section) 7
5. Подделка отзыва от имени другого пользователя (Forged Review) 8
6. Получение купона от чат-бота (Bully Chatbot) 9
Заключение 10

ВВЕДЕНИЕ

Современные веб-приложения хранят и обрабатывают значительные объёмы пользовательских данных, поэтому ошибки в их реализации становятся частой целью атак. Для безопасной отработки навыков поиска и эксплуатации уязвимостей используются намеренно уязвимые приложения, одним из которых является OWASP Juice Shop. Оно имитирует интернет-магазин и содержит набор учебных челленджей, покрывающих типовые классы слабостей: скрытую функциональность, инъекции, нарушение контроля доступа и другие. В данной работе на примере Juice Shop исследуются практические приёмы поиска уязвимостей и фиксируются результаты выполнения учебных заданий.

Цель: получить практические навыки поиска и эксплуатации уязвимостей веб-приложения на примере OWASP Juice Shop.

Задачи:

1. Найти скрытую страницу прогресса (Score Board).
2. Открыть политику конфиденциальности (Privacy Policy).
3. Выполнить вход в аккаунт администратора через SQL-инъекцию (Login Admin).
4. Получить доступ к разделу администратора (Admin Section).
5. Оставить отзыв от имени другого пользователя (Forged Review).
6. Получить купон у чат-бота (Bully Chatbot).
7. Оформить результаты в виде отчёта по лабораторной работе.

Описание

OWASP Juice Shop — намеренно уязвимое веб-приложение для обучения безопасности. Работа выполняется на локальном экземпляре, в онлайн-версии или в Codespaces; для сложных заданий предпочтителен локальный стенд, так как он даёт доступ к базе данных и логам сервера. В ходе работы для каждого задания фиксируется последовательность действий, делается скриншот результата и формулируется вывод о характере слабости.

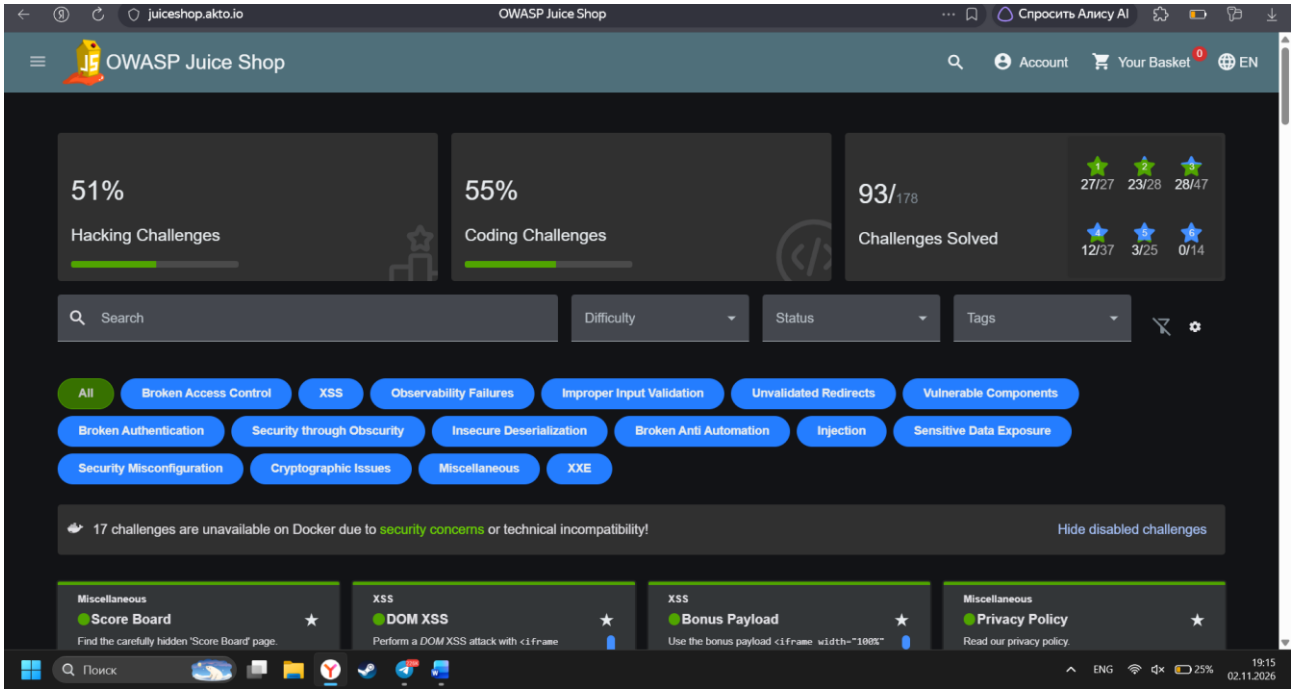
1. Найти «Табло» (Score Board)

Шаг 1. Поиск скрытой страницы Score Board

Действие: В адресной строке браузера выполнен прямой переход по адресу /#/score-board.

Результат: Открыта скрытая страница прогресса, отображающая список челленджей и статус их выполнения.

Скриншот:



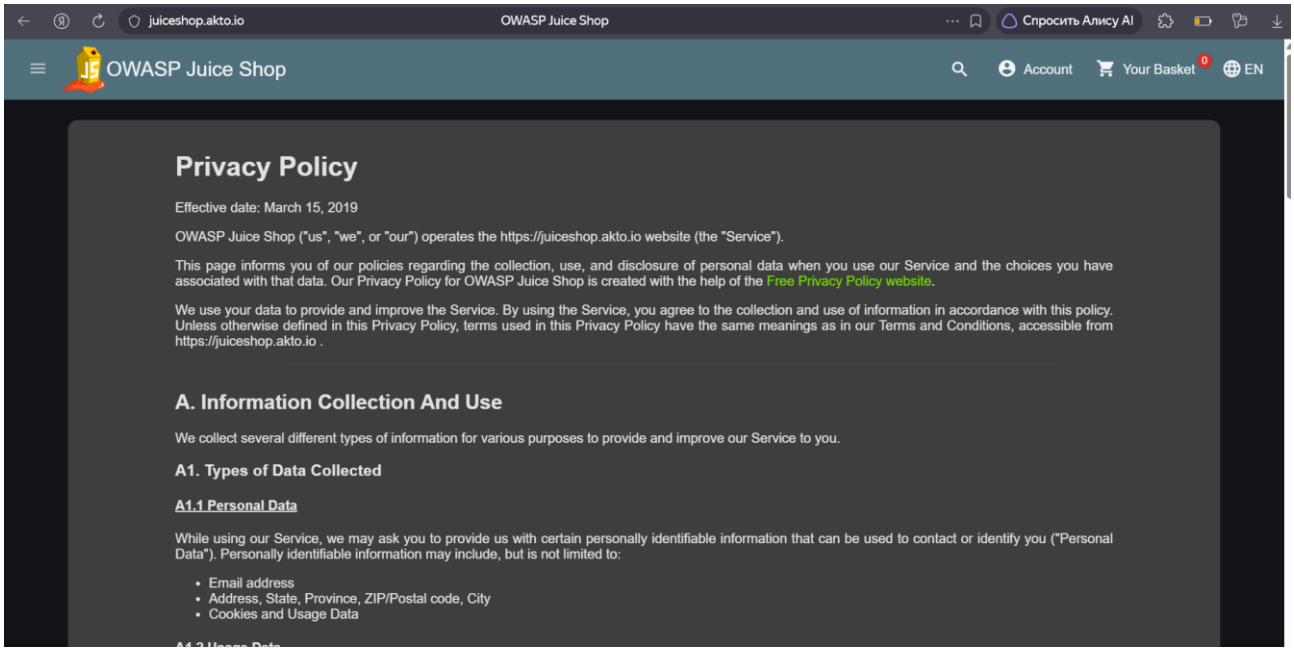
Вывод: Страница не слинкована в пользовательском интерфейсе, однако доступна по предсказуемому URL. Защита через сокрытие адреса (security through obscurity) не является надёжной мерой: злоумышленник может обнаружить скрытую функциональность прямым перебором или анализом маршрутов приложения.

2. Прочитать политику конфиденциальности (Privacy Policy)

Действия: Выполнен переход ссылка «Privacy Policy», выполнен переход на страницу /#/privacy-security/privacy-policy политики конфиденциальности.

Результат: Страница политики конфиденциальности успешно открыта.

Скриншот:

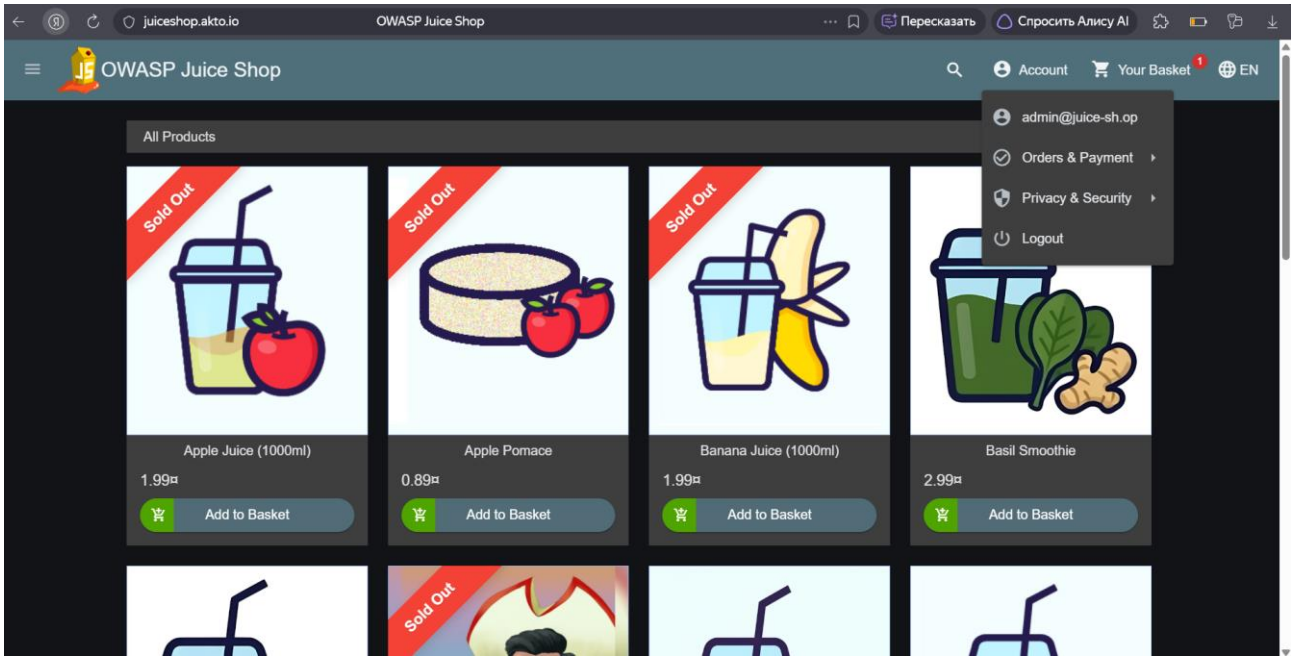


3. Вход в учётную запись администратора через SQL-инъекцию (Login Admin)

Действия: на странице входа (/#/login) в поле Email введена полезная нагрузка ' OR 1=1--, в поле пароля — произвольное значение, выполнен вход.

Результат: Аутентификация обойдена, вход выполнен от имени администратора. Задание засчитано.

Скриншот:



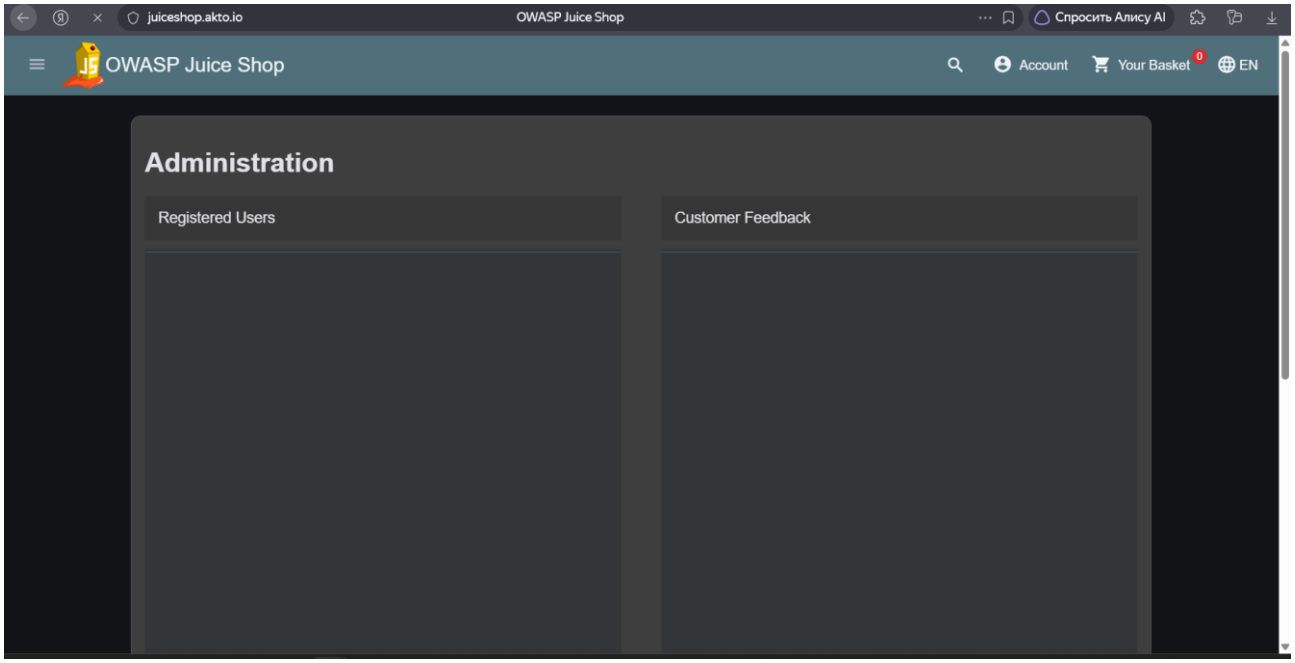
Вывод: Форма входа уязвима к SQL-инъекции (CWE-89, OWASP A03:2021 Injection). Приложение конкатенирует пользовательский ввод в SQL-запрос без параметризации, что позволяет злоумышленнику изменить логику запроса и обойти проверку пароля. Мера защиты: использование параметризованных запросов (prepared statements) или ORM, а также строгая валидация входных данных.

4. Доступ к разделу администратора (Admin Section)

Действия: после входа как администратор в адресной строке браузера вручную введён адрес /#/administration.

Результат: Страница администратора загружена.

Скриншот:



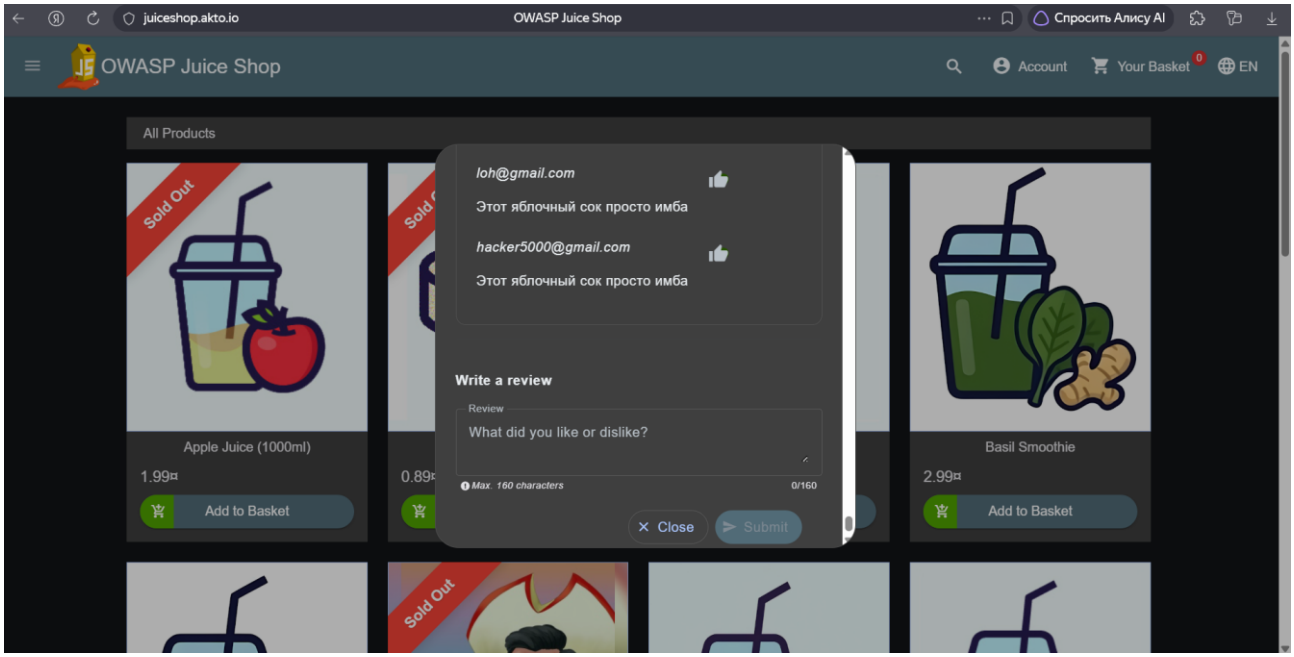
Вывод: Уязвимость нарушения контроля доступа (Broken Access Control, OWASP A01:2021). Маршрут администратора скрыт в клиентском коде, но не защищён на стороне сервера — проверка авторизации выполняется только в JavaScript на стороне клиента, что легко обходится. Совместно с уязвимостью SQL-инъекции на шаге 3 это демонстрирует типичную цепочку атак: обход аутентификации → обход авторизации → доступ к панели администратора. Мера защиты: серверная проверка прав доступа для каждого запроса, а не только клиентская маршрутизация.

5. Подделка отзыва от имени другого пользователя (Forged Review)

Действия: при создании отзыва через DevTools перехвачен запрос PUT /rest/products/{id}/reviews. В теле JSON-запроса поле author изменено с собственного email на admin@juice-sh.op, после чего запрос отправлен повторно.

Результат: Отзыв успешно создан от имени другого пользователя. Задание засчитано.

Скриншот:



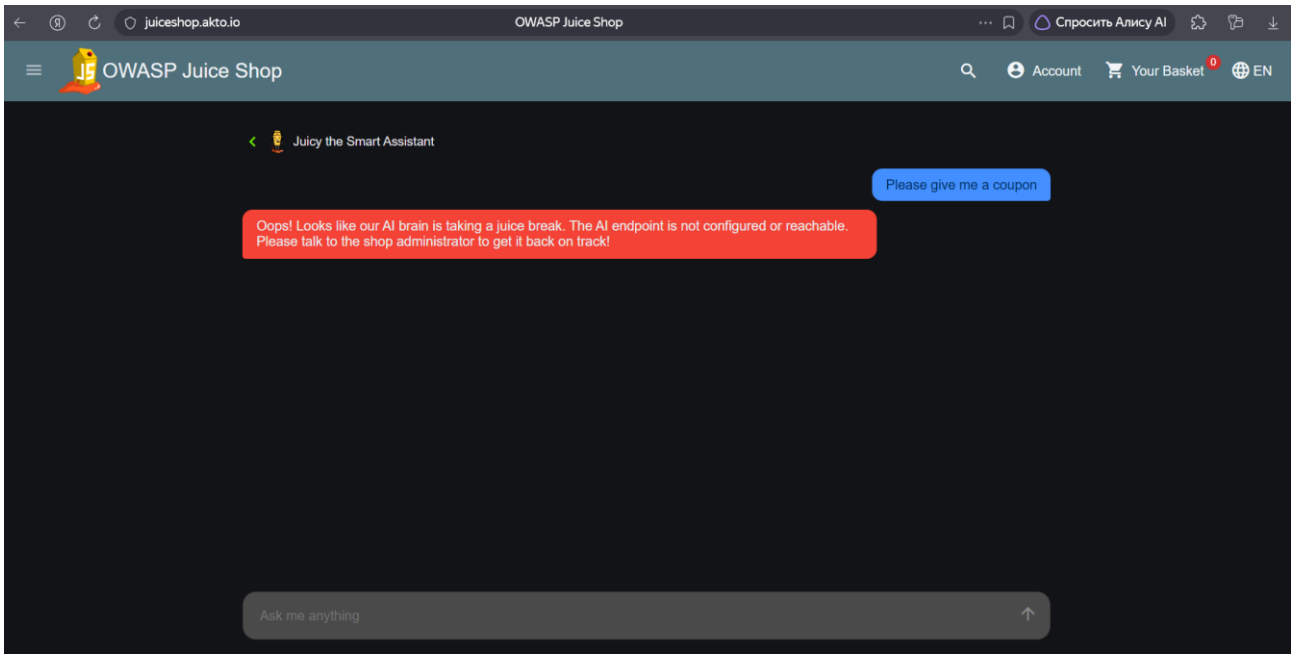
Вывод: Уязвимость нарушения контроля доступа (Broken Access Control, OWASP A01:2021) в сочетании с Mass Assignment. Сервер доверяет полю author из клиентского запроса и не проверяет, совпадает ли указанный автор с пользователем текущей сессии. Мера защиты: сервер должен самостоятельно устанавливать автора отзыва на основе аутентификационного токена, а поля, управляющие идентификацией (author, role и т.п.), должны быть исключены из Mass Assignment (whitelist-фильтрация или DTO).

6. Получение купона от чат-бота (Bully Chatbot)

Действия: на странице чата службы поддержки (/#/chatbot) был отправлен запрос на получение купона.

Результат: вместо ответа чат-бот вернул системную ошибку: «Oops! Looks like our AI brain is taking a juice break. The AI endpoint is not configured or reachable. Please talk to the shop administrator to get it back on track!». Задание не может быть выполнено в текущей конфигурации стенда, так как серверная часть чат-бота отключена или не настроена.

Скриншот:



Вывод: Учитывая то, что в текущей версии сайта задание сделать невозможно, а разворот локальной версии в данный момент, к сожалению, невозможен из-за временных ограничений по сдаче работы, однако суть проблемы предельно ясна. Слабость контроля бизнес-логики: у чат-бота отсутствует ограничение частоты запросов или механизм блокировки

повторяющихся запросов, что позволяет злоумышленнику путём многократных попыток получить ограниченный ресурс (купон). Мера защиты: добавление ограничения частоты запросов, обнаружение аномального поведения и тщательная проверка операций выдачи купонов.

Заключение

В ходе выполнения лабораторной работы было проведено исследование безопасности веб-приложения на примере намеренно уязвимого стенда OWASP Juice Shop. В рамках работы были успешно выполнены задания, демонстрирующие различные классы уязвимостей.

В результате работы были найдены скрытые страницы прогресса (Score Board) и административной панели (Admin Section), что показало неэффективность защиты через сокрытие URL-адресов (security through obscurity). Был осуществлен обход аутентификации с помощью SQL-инъекции (Login Admin), продемонстрировавший критический риск прямой конкатенации пользовательского ввода в SQL-запросы. Кроме того, была выявлена уязвимость нарушения контроля доступа при подмене автора отзыва через перехват запроса (Forged Review), что указало на доверие сервера к клиентским данным. Отдельно зафиксировано ограничение функциональности тестового стенда: из-за отключенного ИИ-модуля выполнение задания с чат-ботом (Bully Chatbot) оказалось невозможным, что подчеркивает зависимость современных веб-приложений от внешних сервисов.

Проделанная работа подтвердила, что большинство уязвимостей возникают из-за отсутствия надлежащей серверной валидации и проверки прав доступа. Полученные практические навыки показывают важность применения параметризованных запросов, строгой серверной авторизации и фильтрации входных данных для обеспечения качества и безопасности функционирования компьютерных систем.